



JUNE 2026

VULNERABILITY ASSESSMENT REPORT

Prepared By:

Malika Bull

**Future Interns Cyber Security
Internship**

Version:
1.0

Table of Contents

Contents

Executive Summary	3
Scope & Objectives	4
Methodology	5
Risk Assessment Overview	6
Findings Summary	7
Detailed Findings	8
WEB-01 - CSP Header Not Set	8
WEB-02 - Missing Anti-Clickjacking Header	9
WEB-03 - X-Content-Type-Options Missing	10
WEB-04 - Server Version Disclosure	11
WEB-05 - Cloudflare Protection Detected	12
WEB-06 - Open Web Services Detected	13
Remediation Priority Matrix	14
Conclusion	15
Appendix – Evidence	16

Executive Summary

A passive vulnerability assessment was conducted against the target website (example.com) using non-intrusive security assessment techniques. The objective was to identify observable security weaknesses, assess associated risks, and provide practical remediation recommendations. The assessment identified several missing security headers and minor information disclosure issues. No critical vulnerabilities were observed during the assessment. Additionally, protective measures such as HTTPS and Cloudflare security services were identified.

Scope & Objectives

This assessment focused on the passive security evaluation of the publicly accessible website example.com. Only non-intrusive testing techniques were performed, including network exposure analysis, HTTP header inspection, and passive vulnerability identification. No exploitation or disruptive testing was conducted.

Objectives

- Assess the security posture of a publicly accessible website using passive assessment techniques.
- Identify observable security weaknesses and misconfigurations.
- Evaluate the potential business impact of identified findings.
- Classify findings according to risk level.
- Provide practical recommendations to improve website security.

Methodology

Procedure

1. Define assessment scope
2. Conduct network exposure analysis using Nmap
3. Conduct passive web assessment using OWASP ZAP
4. Review response headers using Browser Developer Tools
5. Classify findings by risk
6. Develop remediation recommendations

Note: All assessment activities were conducted using passive, read-only techniques in accordance with the project scope. No exploitation, brute-force attacks, authentication bypass attempts, or denial-of-service testing were performed.

Risk Assessment Overview

Metric	Value
Target Website	example.com
Assessment Type	Passive Vulnerability Assessment
Tools Used	Nmap, OWASP ZAP, DevTools
Findings Identified	6
Medium Risk	2
Low Risk	2
Informational	2

Overall Assessment

The assessment identified primarily configuration-related weaknesses involving missing HTTP security headers and minor information disclosure. No critical vulnerabilities were identified during passive testing.

Findings Summary

Ref	Finding	Risk
WEB-01	CSP Header Not Set	Medium
WEB-02	Missing Anti-Clickjacking Header	Medium
WEB-03	X-Content-Type-Options Missing	Low
WEB-04	Server Version Disclosure	Low
WEB-05	Cloudflare Protection Detected	Informational
WEB-06	Open Web Services Detected	Informational

Detailed Findings

WEB-01 - CSP Header Not Set

Finding

Content Security Policy (CSP) Header Not Set

Risk

Medium

Confidence

High

Evidence

OWASP ZAP identified that the target website did not implement a Content Security Policy (CSP) header.

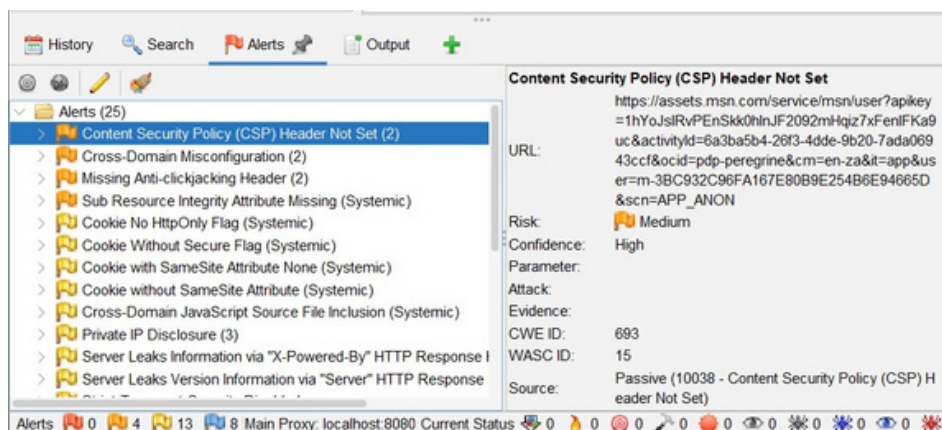


Figure 1 – CSP Header Not Set Alert

Description

A Content Security Policy (CSP) is a security mechanism that instructs web browsers which content sources are trusted and allowed to execute on a website. During the assessment, no CSP header was observed. As a result, the browser has fewer restrictions on what scripts and resources can be loaded and executed.

Business Impact

Without a CSP, the website has reduced protection against malicious or unauthorized content. If an attacker is able to introduce harmful scripts into a webpage, the absence of a CSP may increase the likelihood of those scripts executing within a user's browser. This could negatively impact user trust and website security.

Recommendation

Implement a Content-Security-Policy (CSP) header to define trusted sources for scripts, stylesheets, images, and other web content. This will provide an additional layer of browser-side security and reduce the potential impact of malicious content.

WEB-02 - Missing Anti-Clickjacking Header

Finding

Missing Anti-Clickjacking Header

Risk

Medium

Confidence

Medium

Evidence

OWASP ZAP identified that the target website did not implement a Anti-Clickjacking Header.

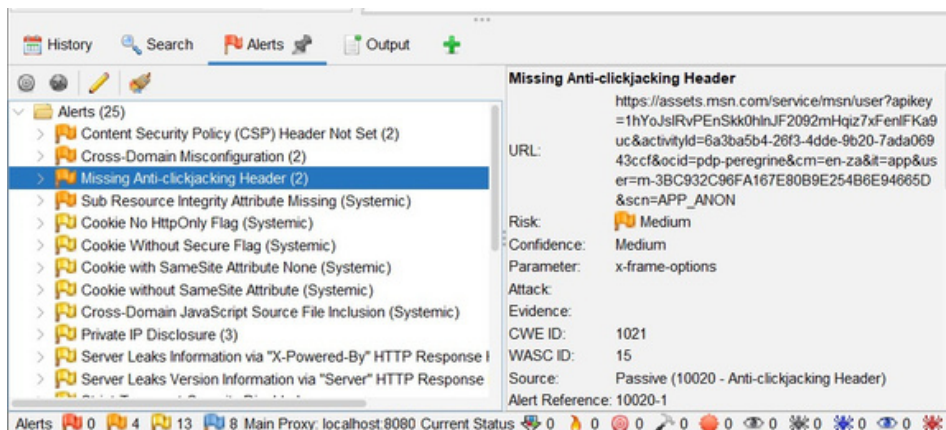


Figure 2 – Missing Anti-Clickjacking Header

Description

A missing anti-clickjacking header indicates that the website does not have protection against being embedded within another website. Anti-clickjacking controls help prevent attackers from displaying the website inside a malicious webpage and misleading users into interacting with content unintentionally.

Business Impact

Without anti-clickjacking protection, the website may be embedded within a malicious webpage that is designed to deceive users. This could result in users clicking buttons, links, or submitting information without realizing their actions, potentially leading to unauthorized transactions, disclosure of information, or loss of user trust.

Recommendation

Implement anti-clickjacking protections such as the X-Frame-Options header or the frame-ancestors directive within a Content Security Policy (CSP). These controls help prevent the website from being embedded within unauthorized webpages and reduce the risk of clickjacking attacks.

WEB-03 - X-Content-Type-Options Header Missing

Finding

X-Content-Type-Options Header Missing

Risk

Low

Confidence

Medium

Evidence

OWASP ZAP identified that the target website did not implement X-Content-Type-Options Header.

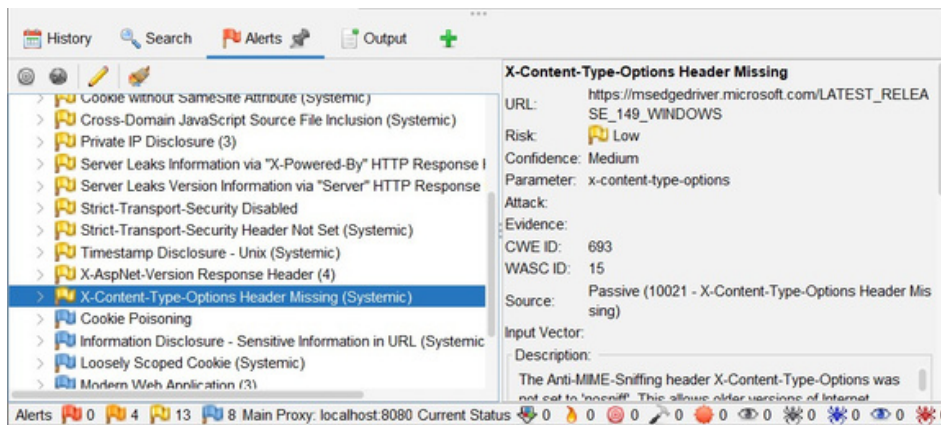


Figure 3 – X-Content-Type-Options Header Missing

Description

The X-Content-Type-Options header was not observed during the assessment. This security header instructs web browsers not to guess (or "sniff") the content type of files and instead rely on the type specified by the website. Without this header, browsers may incorrectly interpret certain files, which can increase the risk of malicious content being executed.

Business Impact

Without the X-Content-Type-Options header, there is an increased risk that a browser could misinterpret the type of content being delivered. While the overall risk is considered low, implementing this header strengthens browser security and helps reduce the possibility of certain attacks that rely on incorrect file type interpretation.

Recommendation

Configure the web server to include the X-Content-Type-Options: nosniff HTTP response header. This ensures browsers only process files as the intended content type and improves the website's overall security posture.

WEB-04 - Server Version Disclosure

Finding

Server Version Disclosure

Risk

Low

Confidence

High

Evidence

OWASP ZAP identified that the target website server Leaks Version Information via "Server" HTTP Response Header Field.

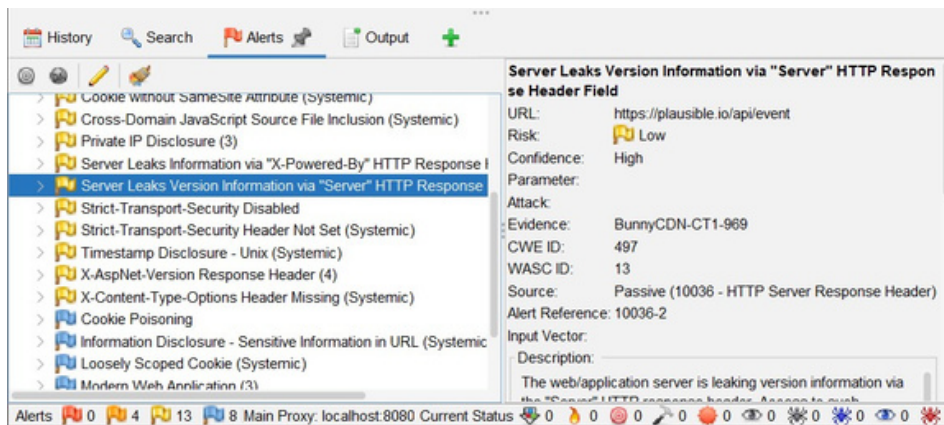


Figure 4 – Server Version Disclosure

Description

The web server was found to disclose version or software information through the Server HTTP response header. Although this information does not directly create a vulnerability, it provides attackers with details about the technologies used to host the website. This information can assist attackers during the reconnaissance phase by helping them identify publicly known vulnerabilities that may affect the software in use.

Business Impact

By revealing details about the underlying web server technology, the website provides attackers with additional information that could be used to plan future attacks. While this finding is considered Low Risk, reducing unnecessary information disclosure follows security best practices and decreases the amount of information available to potential attackers.

Recommendation

Configure the web server to suppress or minimize version and software information contained within the Server HTTP response header. Only expose information that is necessary for normal website operation.

WEB-05 - Cloudflare Protection Detected

Finding

Cloudflare Protection Detected

Risk

Informational

Confidence

High

Evidence

Nmap Service Detection identified the target website as being protected by a Cloudflare HTTP proxy.

```
PS C:\Users\mish> nmap -Pn -sV example.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-24 12:45 +0200
Nmap scan report for example.com (104.20.23.154)
Host is up (0.028s latency).
Other addresses for example.com (not scanned): 2606:4700:10::ac42:93f3 2606:
4700:10::6814:179a 172.66.147.243
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Cloudflare http proxy
443/tcp   open  ssl/http Cloudflare http proxy
8080/tcp  open  http    Cloudflare http proxy
8443/tcp  open  ssl/http Cloudflare http proxy

Service detection performed. Please report any incorrect results at https://
nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 49.45 seconds
```

Figure 5 – Cloudflare Protection Detected

Description

The Nmap service detection scan identified that the target website is using Cloudflare as a web proxy and content delivery network (CDN). Cloudflare provides additional security features such as traffic filtering, Distributed Denial-of-Service (DDoS) protection, Secure Socket Layer (SSL/TLS) support, and performance optimization.

Business Impact

The use of Cloudflare improves the website's overall security posture by helping protect against common internet-based threats and improving website availability and performance. While this is not a vulnerability, it demonstrates that the organization has implemented an additional layer of security.

Recommendation

Continue using Cloudflare and regularly review its security configuration to ensure features such as Web Application Firewall (WAF), SSL/TLS settings, and DDoS protection remain properly configured and up to date.

WEB-06 - Open Web Services Detected

Finding

Open Web Services Detected

Risk

Informational

Confidence

High

Evidence

The Nmap network scan identified the following publicly accessible web service ports:

TCP Port 80 (HTTP)

TCP Port 443 (HTTPS)

TCP Port 8080 (HTTP Alternative)

TCP Port 8443 (HTTPS Alternative)

```
PS C:\Users\mish> nmap -Pn example.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-24 12:45 +0200
Nmap scan report for example.com (104.20.23.154)
Host is up (0.032s latency).
Other addresses for example.com (not scanned): 172.66.147.243 2606:4700:10::
6814:179a 2606:4700:10::ac42:93f3
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
8080/tcp  open  http-proxy
8443/tcp  open  https-alt
Nmap done: 1 IP address (1 host up) scanned in 7.09 seconds
```

Figure 6 – Open Web Services Detected

Description

The assessment identified four publicly accessible web service ports that allow users to connect to the website. These services are necessary for delivering web content and secure communications over the internet. No unnecessary or unexpected network services were identified during the assessment.

Business Impact

Exposed web services are required for normal website operation; however, every publicly accessible service increases the potential attack surface of the website. Maintaining only the services that are required helps reduce unnecessary security risks.

Recommendation

Continue restricting public access to only the services required for website operation. Regularly review firewall rules and network configurations to ensure unnecessary ports and services remain disabled and monitor exposed services for unusual activity.

Remediation Priority Matrix

Priority	Recommendation
High	Implement CSP
High	Implement Anti-Clickjacking Controls
Medium	Add X-Content-Type-Options
Medium	Reduce Server Information Disclosure
Low	Review Open Services Periodically

Conclusion

A passive vulnerability assessment was conducted against example.com using industry-standard security assessment tools. The assessment identified several low-to-medium risk findings related to missing security headers and information disclosure. Existing security controls, including HTTPS and Cloudflare protection, were observed. Implementing the recommended remediation actions would strengthen browser-level protections and improve the website's overall security posture.

Nmap Basic Scan

Nmap Service Detection Scan

Anti-Clickjacking Alert



CSP Alert

The screenshot shows the Burp Suite Alerts tab with the 'Content Security Policy (CSP) Header Not Set' alert selected. The alert details are as follows:

- URL:** https://assets.msn.com/service/msn/user?apikey=1hYoJslRvPEnSkk0hlnJF2092mHqiz7xFenIFKa9uc&activityId=6a3ba5b4-26f3-4dde-9b20-7ada06943ccf&ocid=pdp-peregrine&cm=en-za&it=app&user=m-3BC932C96FA167E80B9E254B6E94665D&scn=APP_ANON
- Risk:** Medium
- Confidence:** High
- Parameter:**
- Attack:**
- Evidence:**
- CWE ID:** 693
- WASC ID:** 15
- Source:** Passive (10038 - Content Security Policy (CSP) Header Not Set)

The bottom status bar shows 0 Alerts, 4 Information, 13 Warning, and 8 Main Proxy: localhost:8080 Current Status.

Server Disclosure Alert

The screenshot shows the Burp Suite Alerts tab with the 'Server Leaks Version Information via "Server" HTTP Response Header Field' alert selected. The alert details are as follows:

- URL:** <https://plausible.io/api/event>
- Risk:** Low
- Confidence:** High
- Parameter:**
- Attack:**
- Evidence:** BunnyCDN-CT1-969
- CWE ID:** 497
- WASC ID:** 13
- Source:** Passive (10036 - HTTP Server Response Header)
- Alert Reference:** 10036-2
- Input Vector:**
- Description:** The web/application server is leaking version information via the "Server" HTTP response header. Assets to such

The bottom status bar shows 0 Alerts, 4 Information, 13 Warning, and 8 Main Proxy: localhost:8080 Current Status.

X-Content-Type-Options Alert

The screenshot shows the Burp Suite Alerts tab with the 'X-Content-Type-Options Header Missing' alert selected. The alert details are as follows:

- URL:** https://msedgedriver.microsoft.com/LATEST_RELEASE_149_WINDOWS
- Risk:** Low
- Confidence:** Medium
- Parameter:** x-content-type-options
- Attack:**
- Evidence:**
- CWE ID:** 693
- WASC ID:** 15
- Source:** Passive (10021 - X-Content-Type-Options Header Missing)
- Input Vector:**
- Description:** The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'no sniff'. This allows older versions of Internet

The bottom status bar shows 0 Alerts, 4 Information, 13 Warning, and 8 Main Proxy: localhost:8080 Current Status.

Browser Development Tools

